Права безопасности объектов в домене

Основные атрибуты:

- objectSID - идентификатор безопасности пользователя
- AccountExpires - указатель срока истечения действия учётной записи
- PasswordExpirationDate - указатель срока истечения действия пароля
- BadpwdCount - количество неудачных попыток входя пользователя, когда был неверный пароль
- LastLogin - последний вход в систему
- PwdLastSet - время последнего изменения пароля

AAA

1. Идентификация (identification) - позволяет уникально идентифицировать объект (пользователь, группа, ПК) безопасности
2. Аутентификация (authentication) (проверка подлинности) - проверка частной информации (пароль, пинкод и тп) для аутентификации
3. Авторизация (authorization) - подтверждение подлинности субъекта безопасности
4. Отчётность (accounting) - сохранение событий авторизации а предназначенные для этого службы

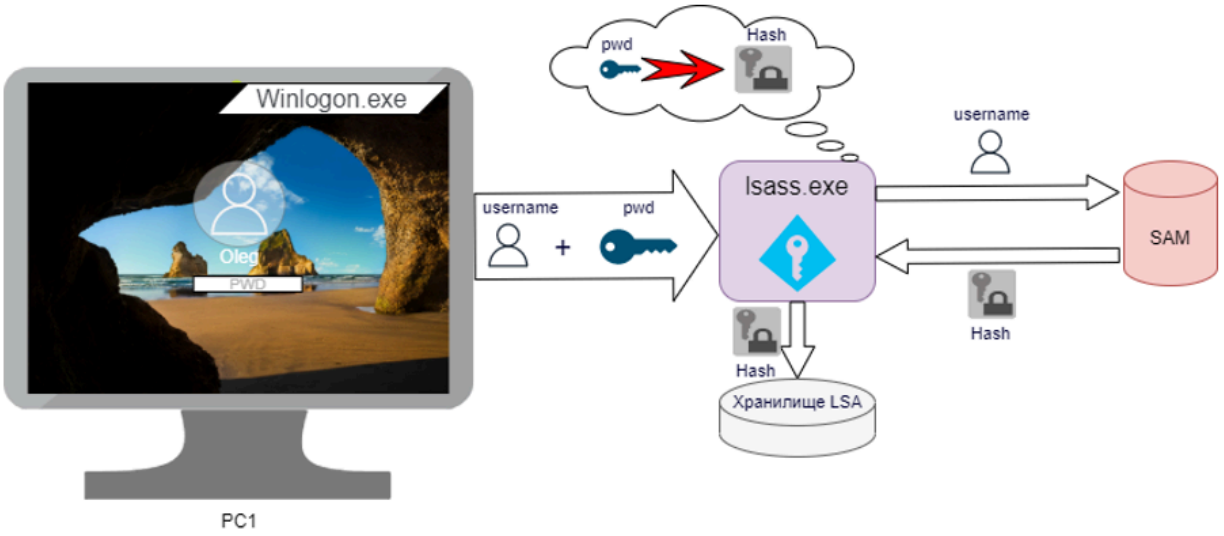
   Эти действия выполняются в таком порядке, какой указан в списке.

Ввод учётных данных в Windows

Winlogon - это графический системный процесс, который выполняет процедуры входа и выхода на компьютерах с Windows.
Функции процесса:

- работоспособность и защита рабочего стола
- контроль хранителя экрана (скринсейвера)
- загрузка пользовательских профилей
- обеспечение безопасности пользовательских данных
- поддержка входа и выхода пользователя из системы

Алгоритм локальной аутентификации показан на рисунке ниже.



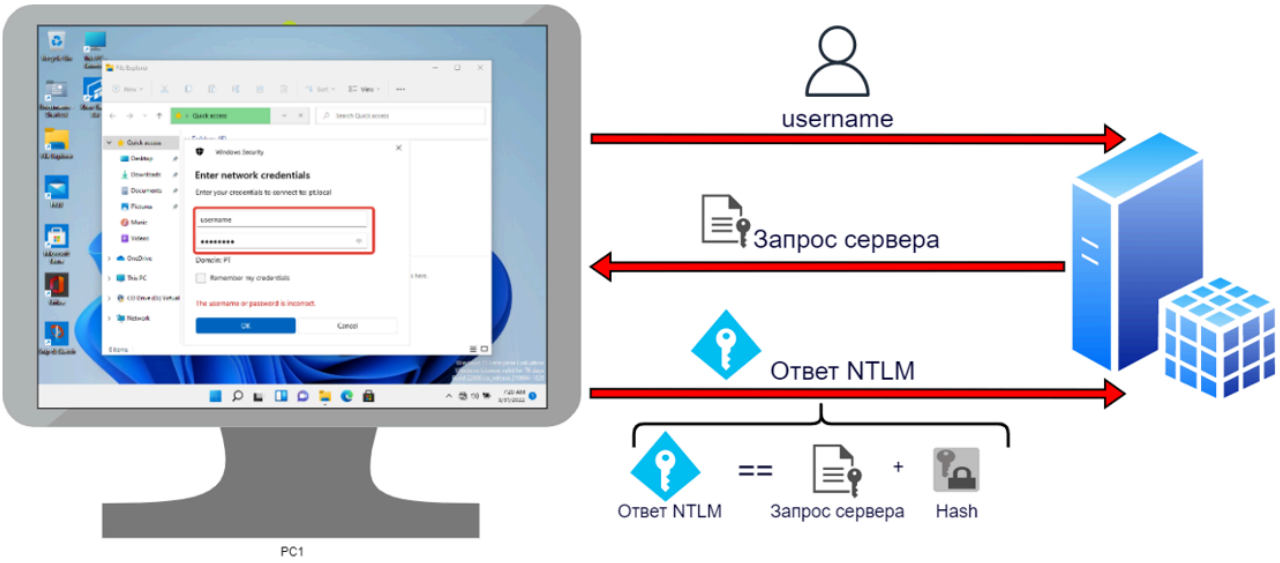
Протоколы аутентификации: LM и NTLM

Lan Manager (LM)

Он появился в Windows 3.11 для рабочих групп. Не используется в современных системах, но всё ещё поддерживается. Пароль регистронезависим, то есть любой пароль приводится в вид, когда все символы капсом написаны. Длина пароля - 14 символов. Более короткие пароли дополняет система, приписывая при создании хэша нули. Пароль здесь делят пополам и для каждой части делается свой хэш по алгоритму DES. Хэш в этом протоколе почти никак не защищён и очень быстро расшифровывается.

New Technology Lan Manager (NTLM)

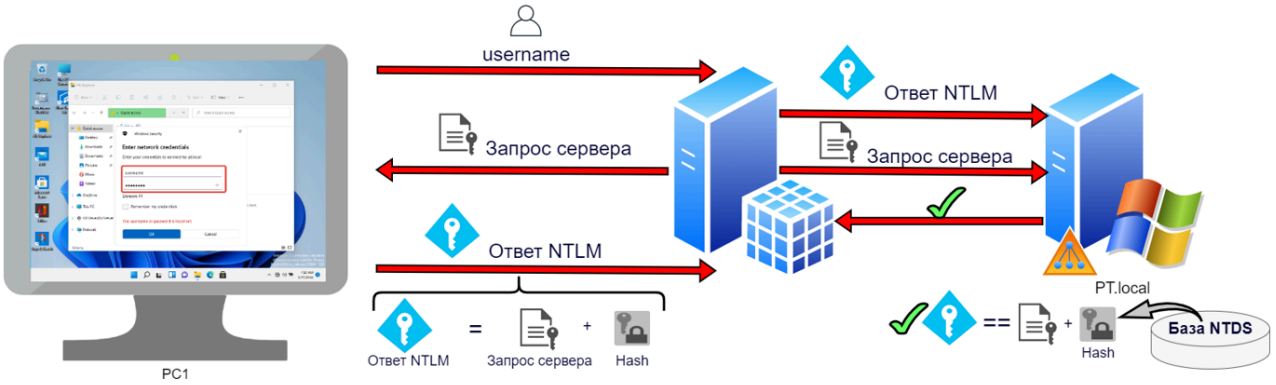
Здесь хэш уже формируется не по алгоритму DES, а по MD4. Пароль может быть длиной до 128 символов и является регистрозависимым. Использовать здесь можно уже не только символы ACSII, но и Unicode.
NTLM работает по алгоритму, показанному на рисунке ниже.



Примечание: запрос сервера - это случайно сгенерированное число.
NTLM сейчас неактуален из-за атак, которые нельзя легко нейтрализовать.

NetLogon

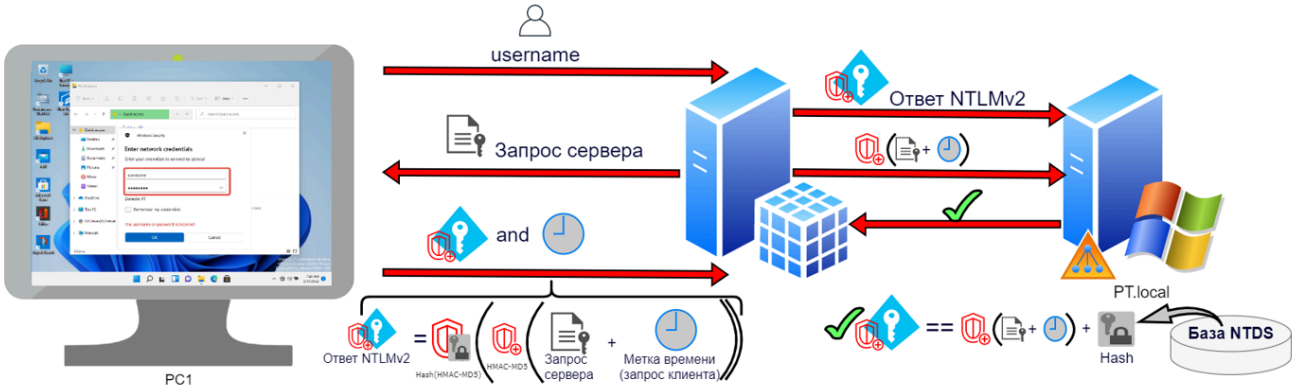
Служба WIndows, работающая в рамках доменного взаимодействия.
Эта служба автоматически работает и отвечает за проверку подлинности пользователей. Она поддерживает безопасный канал между компьютером и контроллером домена. Служба передаёт на контроллер домена данные пользователя, а возвращает доменные идентификаторы безопасности и назначенные пользователю права. Обычно такой процесс называется сквозной проверкой подлинности.
Алгоритм сетевой аутентификации NTLM показан на рисунке ниже.



NTLMv2

Более актуальная версия NTLM. Хэширование с помощью MD5. Появилась метка времени, которая нужна чтобы защититься от атаки с накоплением данных злоумышленника.

Алгоритм NTLMv2 показан на рисунке ниже.



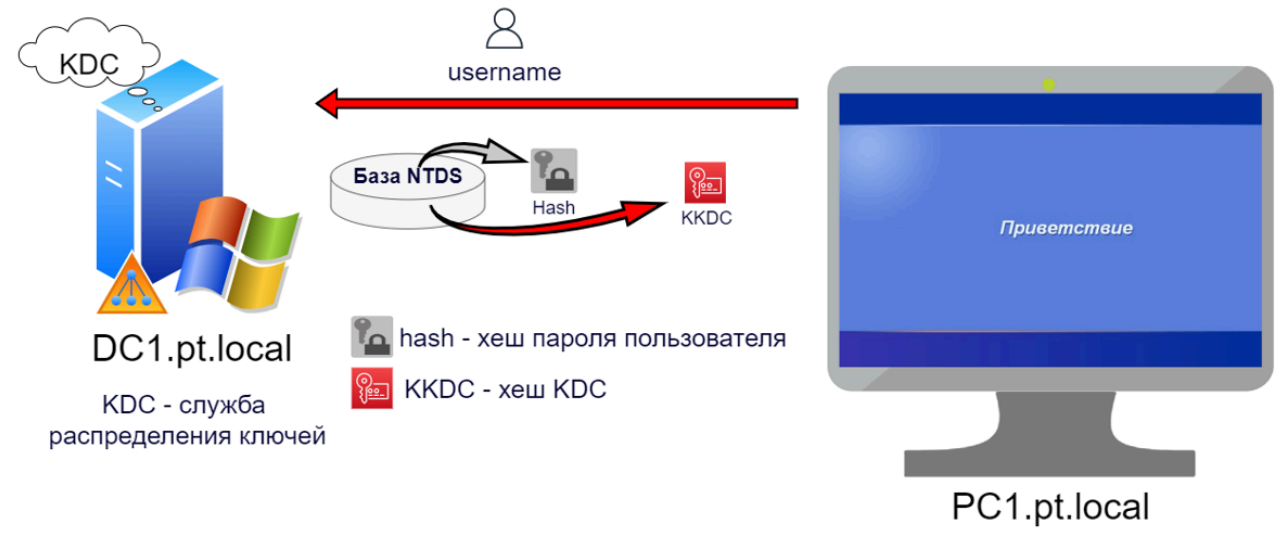
1. Из пароля пользователя в виде Unicode строки при помощи алгоритма MD4 вычисляется **NTLM-hash**, состоящий из 16 байт. Например, пароль « `SecREt01` » или Unicode строка `0x530065006300520045007400300031 00` после преобразования посредством алгоритма MD4 будет иметь вид: `0xcd06ca7c7e10c99b1d33b7485a2ed808` .
2. Имя пользователя и имя домена в виде Unicode строк объединяются и приводятся к верхнему регистру. Далее, из этой последовательности и ранее полученного **NTLM-hash** при помощи алгоритма HMACMD5 вычисляется **NTLMv2-hash**, состоящий из 16 байт. Например, имя пользователя « `User` » и имя домена « `Domain` » дадут строку « `USERDOMAIN` » или Unicode строку `0x550053004500520044004f004d00410049004e00` . После алгоритма HMACMD5, где применяется **NTLM-hash**, вычисляется **NTLMv2-hash** : `0x04b8e0ba74289cc540826bab1dee63ae` .

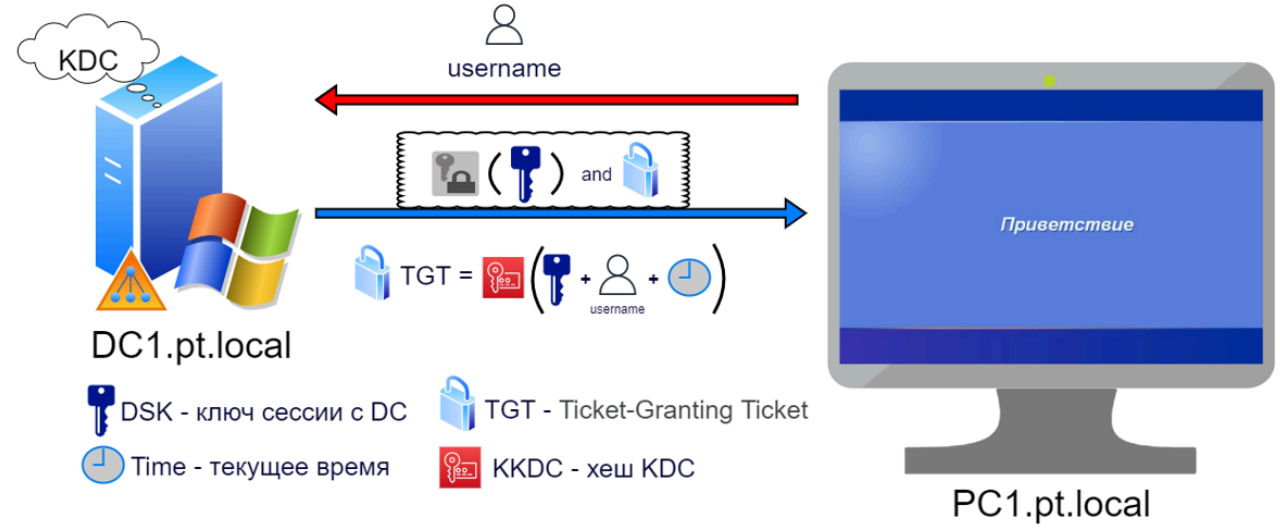
Kerberos

Протокол, обеспечивающий надёжную аутентификацию пользователей. Этот протокол предусматривает, что обмен информацией между клиентом и сервером происходит в незащищённой среде, а передаваемые пакеты могут быть перехвачены. Этот протокол решает задачу подтверждения двух сторон через контроллер домена. Kerberos работает с помощью билетов.

KDC - key distribution center
TGT - ticket-granting ticket

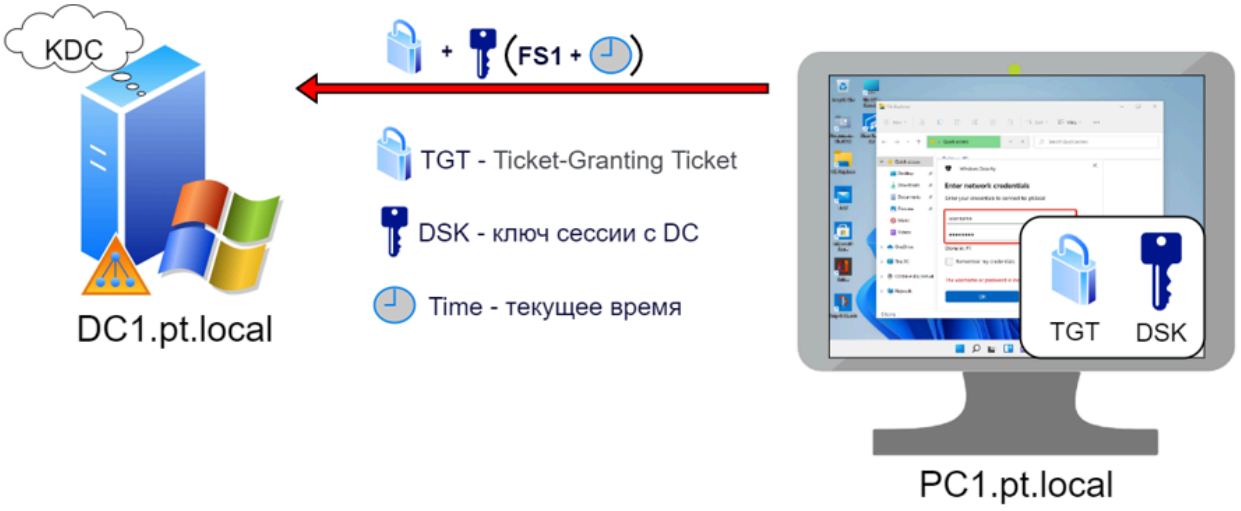
На рисунках ниже представлен алгоритм получения TGT.

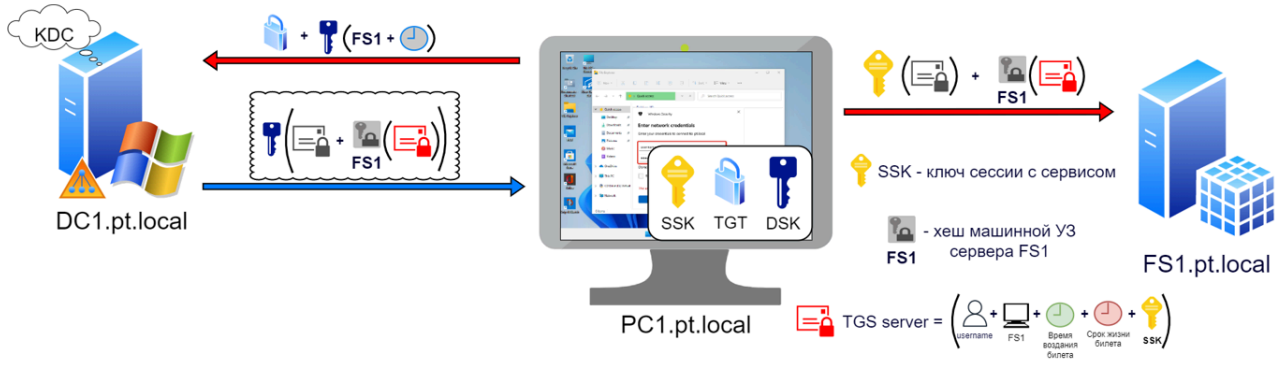


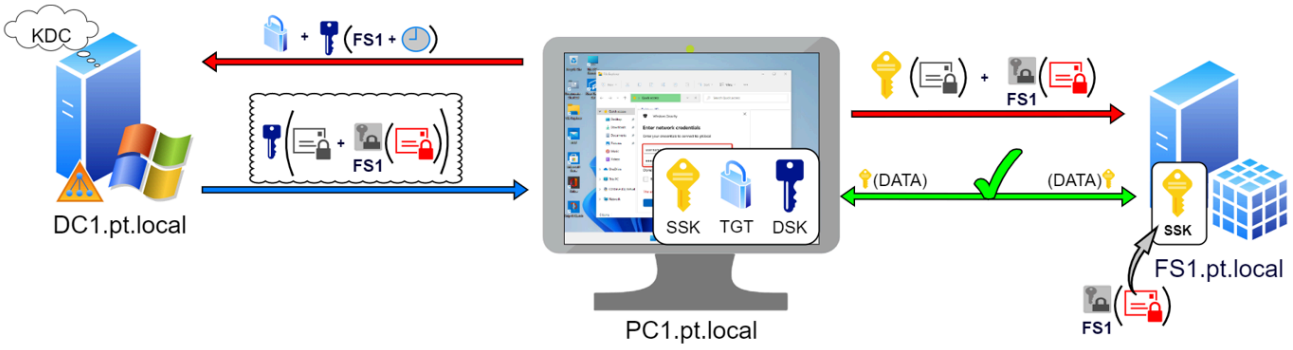


DSK - ключ сессии с DC (domen controller)
SSK - ключ сессии с сервером

На рисунках ниже представлен алгоритм "получения" TGS (ticket-granting service).







Примечание: Kerberos сильно зависит от времени, которое установлено на компьютерах. Если время на проверяющем компьютере и на компьютере пользователя отличается больше чем на минут, то аутентификация будет принудительно переведена на NTLM.

Типы входа в Windows

При просмотре информации журналов события будут отображаться с разным logon type. Этот параметр отвечает за то, как именно была вызвана учётная запись.

Тип входа 2: Интерактивный	**Пользователь непосредственно вошел на этот компьютер, используя клавиатуру и введя имя пользователя и пароль в окне входа в систему**
Тип входа 3: Сетевой	Пользователь по сети подключился к этому компьютеру и авторизовался на нем. Например, получив доступ до сетевой папки
Тип входа 4: Пакетный	Этот тип входа используется при выполнении пакетных заданий без непосредственного участия пользователя
Тип входа 5: Служба	Такое событие возникает когда Windows запускает службу от имени пользователя
Тип входа 7: разблокирование	Такое событие возникает когда Windows запускает службу от имени пользователя
Тип входа 8: NetworkCleartext	Это событие возникает, если пароль пользователя был получен по сети открытым текстом. Например, вход в IIS с помощью базового метода аутентификации
Тип входа 9: NewCredentials	Это событие регистрируется, когда используется команда "Запустить от имени" вместе с опцией "/netonly". Это нужно для запуска программы с дополнительными привилегиями для сетевых компьютеров
Тип входа 10: RemoteInteractive	Пользователь выполнил удаленный вход на этот компьютер, используя Terminal Services или Remote Desktop
Тип входа 11: CachedInteractive	Пользователь вошел на этот компьютер с сетевыми учетными данными, которые хранились локально на компьютере. Контроллер домена не использовался для проверки учетных данных

Кэширование учётных данных

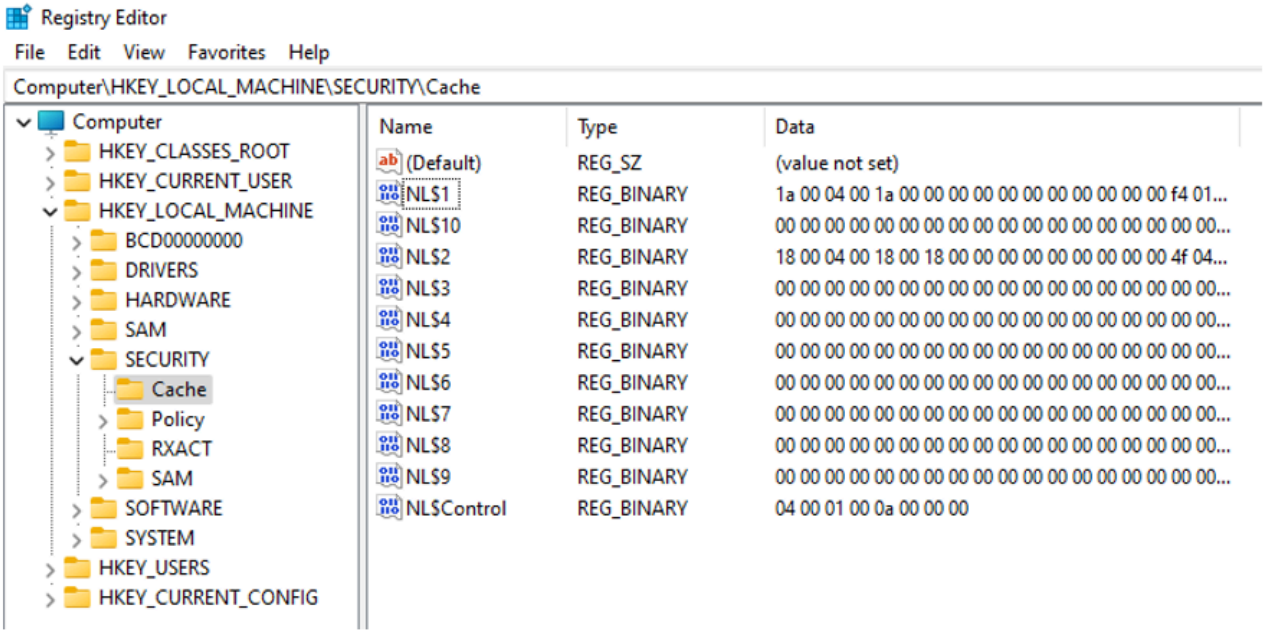
Кэширование учётных записей делается для удобства взаимодействия с Windows. Для кражи учётных данных используется программа mimikatz. Её интерфейс показан

на рисунке ниже.

```
Select mimikatz 2.2.0 x64 (oe.eo)

  .#####.   mimikatz 2.2.0 (x64) #19041 Aug 10 2021 17:19:53
 .## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
 ## / \ ##  /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
 ## \ / ##       > https://blog.gentilkiwi.com/mimikatz
 '## v ##'       Vincent LE TOUX             ( vincent.letoux@gmail.com )
  '#####'        > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # privilege::debug
Privilege '20' OK

mimikatz # sekurlsa::logonPasswords full

Authentication Id : 0 ; 478038 (00000000:00074b56)
Session           : Interactive from 1
User Name         : ignat.saraev
Domain            : PT
Logon Server      : DC1
Logon Time        : 4/6/2022 12:35:50 AM
SID               : S-1-5-21-1161718399-3677933811-1383400880-1103
        msv :
         [00000003] Primary
         * Username : ignat.saraev
         * Domain   : PT
         * NTLM     : a2de9aff21118f0177b3f9846fcd1e56
         * SHA1     : 8c3004bcf9fc2c18ea304ad7bcac743dbf96ba5b
         * DPAPI    : 93eaa3401b386f5e63033e6a59430f5b
```

Учётные данные в реестре

По умолчанию даже у админа нет прав на просмотр содержимого этой ветки реестра. Для целенаправленного просмотра ветки можно использовать redegit.exe от имени системы. Сделать это можно с помощью PsExec по команде "PsExec.exe -i -s redegit.exe", где "-s " означает, что приложение запускается от имени системы. Реестр будет выглядеть примерно также, как на рисунке ниже.



Примечание: по умолчанию Windows плохо сам себя логирует, поэтому лучше это настраивать вручную.

[практика 3. AAA в Windows]